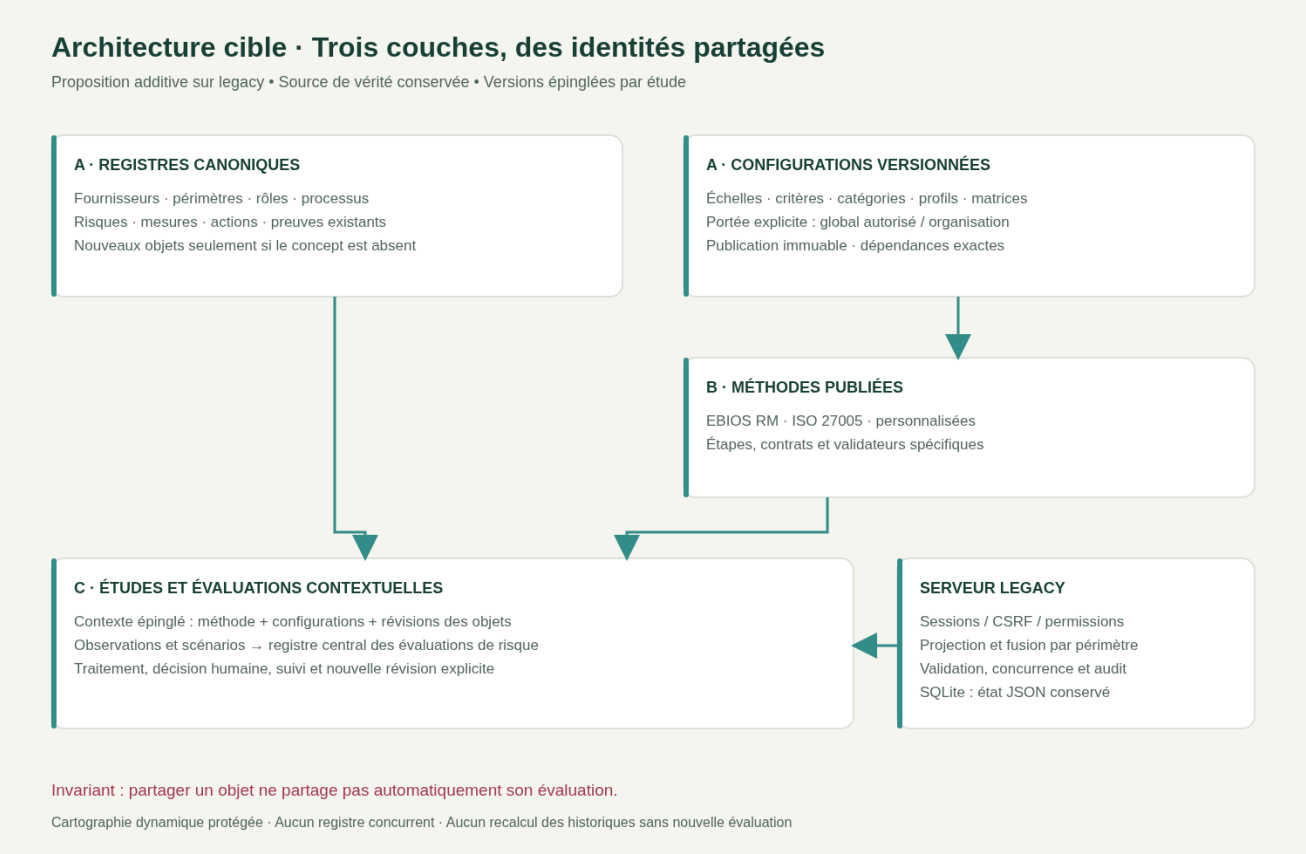
Socle GRC transversal

Dossier technique d’implémentation

Analyse ARM • Architecture • Parcours • Migration • Recette • Prompt IA



Version 1 — 14 octobre 2026
Spécification proposée, non intégrée, à valider.
Les documents Markdown et contrats JSON du ZIP sont la référence pour l’IA qui code.

Dossier d’implémentation — socle GRC transversal

Version 1 • 14 octobre 2026 • **Spécification proposée, intégration non réalisée, validation métier à obtenir.**

Ce dossier traduit l’analyse de l’export ARM et du code legacy en une refonte progressive de l’application existante. Il est destiné à une IA qui code. Les maquettes décrivent la cible ; elles ne prouvent pas l’existence des fonctions dans l’application.

Commencer

1. Lire le diagnostic et l’analyse ARM.

2. Étudier les registres et configurations, l’architecture, les contrats et les parcours.

3. Ouvrir la galerie graphique, ou les captures, puis lire les spécifications UX.

4. Suivre la migration, les lots techniques, la recette les décisions et la navigation simplifiée issue de la vidéo.

5. Donner à l’IA le prompt d’exécution. Elle travaille exclusivement sur sa propre branche, depuis origin/legacy en lecture.

Périmètre et preuves

Code audité : 472a81fe315ac323d75a59db74e16b8d39a5b0e8, branche legacy. L’audit porte sur le code suivi par Git, pas sur une base de production. L’export contient 25 fichiers, dont 21 classeurs, 3 images et un cache système. Il documente les ateliers 1 et 2, pas une étude complète ni un schéma de base de données.

Les qualifications **observé**, **déduit** et **proposé** sont distinctes. Les données métier réelles, les fichiers sources et les images ARM ne sont pas publiés. Le dossier public conserve les structures, les comptes, les règles visibles et des illustrations fictives.

Livrables machine : inventaire des 25 fichiers, colonnes des 21 classeurs, échelles observées, matrice de pertinence, schéma de contrat, exemple synthétique, traçabilité des exigences, vérifications du dossier.

Les normes ne sont pas réécrites. Le guide officiel ANSSI est cité dans le dossier ; les barèmes ARM restent des configurations locales. Le texte intégral ISO/IEC 27005 n’a pas été audité ici.

Navigation simplifiée ajoutée après la vidéo

Sept familles métier et Administration séparée ; doublons confirmés, correspondances de routes et conservation des fonctions dans le chapitre 12. Arborescence JSON · Correspondances CSV.

Lecture et ouverture locale

PDF technique complet · PDF des dix vues · Aperçu de la navigation. Extraire le ZIP complet ; ouvrir graphiques/DEMARRER.bat sous Windows ou graphiques/index.html dans un navigateur.

Diagnostic de l’existant

Constat vérifié dans le code

Élément	Preuve au SHA audité	Conséquence
Application HTML/JS avec API Python locale	index.html, modules/, legacy_server.py	Évolution additive ; aucune nouvelle application parallèle.
État métier JSON stocké dans SQLite	legacy_server.py:69 et :730	Le modèle conceptuel proposé n’est pas une liste de tables SQL existantes.
Sessions, CSRF, permissions et périmètres côté serveur	legacy_server.py:137, :165, :169, :217, :635	Toute nouvelle collection exige projection, fusion et validation serveur.
Registres partagés	legacy_server.py:17, modules/integration-core.js:213	Réutiliser fournisseurs, processus, périmètres, rôles, preuves, actions, mesures de conformité.
Huit collections du registre des risques	modules/risk-core.js:74, legacy_risks.py	Risque, étude, scénario, évaluation, politique, traitement, mesure, décision restent distincts.
Quatre noms de méthodes	modules/risk-core.js:15	EBIOS RM, ISO 27005, MÉHARI et Personnalisée sont des libellés existants, pas quatre moteurs complets.
Politiques déjà versionnées	modules/risk-core.js:139, legacy_risks.py	Ne pas reconstruire un second registre des politiques ni perdre les identifiants actuels.
Matrices configurables, revalidées côté serveur	modules/risk-core.js:299, legacy_risks.py	Les valeurs par défaut ne constituent pas un barème ANSSI. Le calcul uniforme n’est pas imposé.
Évaluations, politiques et décisions immuables	legacy_risks.py	Préserver les snapshots ; compléter par liaisons ou nouvelles versions, sans réécriture historique.
Cinq ateliers sous forme de zones de texte	modules/risk-ui.js:122–173, :905	Structurer les livrables et relations ; conserver les anciens textes comme notes héritées.
SR, événement redouté, supports textuels	modules/risk-core.js:270–296, modules/risk-ui.js:207	Introduire des références typées et conserver le texte d’origine lorsqu’un rapprochement est ambigu.
Annexe A ISO 27001:2022 reliée aux risques	modules/risk-core.js:211, legacy_risks.py	Garder les objectRefs bidirectionnels. Une association ne prouve ni conformité ni réduction du risque.
Concurrence optimiste	legacy_server.py:735	Préserver le rejet 409 ; aucune fusion automatique de validations concurrentes.

Ces lignes sont des repères au SHA d’audit. L’agent doit rechercher les symboles au SHA de son départ et consigner les écarts. docs/ARCHITECTURE.md est historique : ne pas en déduire que le serveur n’existe pas.

Manques observés et limites de l’audit

Il manque un registre explicite des versions de méthodes, une résolution transversale des configurations et un ensemble d’objets structurés pour les cinq ateliers. Les études n’épinglent pas aujourd’hui un bundle complet de méthode et de configurations ; les évaluations épinglent déjà leur politique. Le registre actuel de scénarios mélange plusieurs types, dont « Source de risque » et « Événement redouté » : distinguer à

terme leurs concepts, sans déplacer automatiquement les historiques.

Aucun registre canonique général d’actifs, de valeurs métier ou de supports n’a été identifié dans les modules examinés. L’agent doit compléter l’inventaire des collections suivies par Git avant création : une absence dans cette lecture ciblée n’est pas une preuve d’absence dans tout le dépôt. suppliers existe mais n’apparaît pas dans le dictionnaire LegacyIntegration.collections() examiné : ajouter un adaptateur, pas un deuxième fournisseur.

Les périmètres de visibilité existent ; une isolation complète par organisation indépendante n’est pas démontrée. Ne pas assimiler automatiquement établissement, GHT, tenant et organisation propriétaire. Leur correspondance doit être explicitement définie avant activation multi-organisation.

Les fichiers non suivis apps/, packages/ et tests/e2e/ sont étrangers à ce travail et ne fondent pas le diagnostic. Aucune base réelle .legacy-data n’a été auditée.

Préserver impérativement

La cartographie dynamique, son interface, ses données et ses interactions restent intactes : modules/carto-core.js, modules/carto-ui.js, modules/carto.css, legacy_cartography.py, routes carto et dash/map, éléments dmap, mb-ctx, mb-proc. Les nouvelles matrices et graphes EBIOS sont isolés dans la gestion des risques.

Conserver les fonctions de conformité, audits, PCRA, plans d’action, tâches récurrentes, preuves, administration et parcours existants. La refonte ne vaut pas validation des maquettes précédentes et ne remplace aucun registre d’actions ou de preuves.

Analyse exhaustive de l’export ARM

Méthode et limites

Les 25 entrées utiles ont été inventoriées : chaque classeur a été ouvert, toutes ses feuilles et cellules non vides lues, les plages fusionnées et les remplissages inspectés ; les trois PNG ont été examinés visuellement. Les 21 classeurs ont chacun une feuille visible Sheet1, sans formule ni table Excel structurée. Le cache Thumbs.db est exclu du modèle métier. L’inventaire avec empreintes et le relevé de colonnes sont en annexes.

L’export n’est ni le code d’ARM, ni sa base complète, ni une preuve de cardinalités globales. Les références sont principalement des libellés et abréviations. # indique une ligne exportée ; ✓/☐ est un marqueur exporté dont la sémantique exacte n’est pas documentée. Aucun des deux ne devient un identifiant métier ou un statut actif par défaut.

Contenu, fichier par fichier

Atelier	Fichier	Observations	Classement cible
1	Base d’évènements redoutés	17 entrées ; VM vide ; critère, besoin, impacts, gravité proposée/retenue, description	Modèle d’événement réutilisable séparé de son évaluation dans l’étude
1	Base de catégories d’impact	4 catégories ; parent et abréviation vides	Taxonomie organisationnelle
1	Base de critères de sécurité	3 critères : disponibilité, intégrité, confidentialité ; échelle de besoin associée	Critères et associations de versions d’échelles
1	Base de responsables	13 entrées de rôles/services/prestataires ; associations VM/supports vides	Rapprochement avec rôles et organisations, pas création automatique de comptes
1	Biens supports	2 objets ; catégorie Matériels ; propriétaire libellé ; parent vide ; numéros exportés 3 et 4	Registre d’actifs/supports canonique
1	Catégories de bien support	9 catégories hiérarchiques ; certaines très spécifiques	Taxonomie ; les catégories ne créent pas automatiquement des applications
1	Définir le cadre de l’étude	1 étude, confidentialité et langue ; durées des cycles et contraintes vides	Instance et contexte de l’étude
1	Identifier les missions et l’objet de l’étude	89 lignes physiques, **9 missions**, 60 plages fusionnées ; aucune valeur VM/support dans D:I	Missions et associations à compléter, pas 89 missions
1	Impacts	16 définitions = 4 catégories × 4 niveaux	Profils d’impact configurés ; pas 16 évaluations de risques
1	Échelle d’intégrité	3 niveaux	Échelle qualitative de besoin
1	Échelle de confidentialité	4 niveaux	Échelle qualitative de besoin
1	Échelle de disponibilité	4 niveaux avec descriptions de durée	Échelle qualitative ; seuils non normalisés
1	Échelle de gravité	4 niveaux G1 à G4 ; valeur indicative vide	Échelle ordinale, valeur numérique non imposée

Atelier	Fichier	Observations	Classement cible
1	Échelle de niveau d’impact	4 niveaux ; correspondance explicite vers G1 à G4	Échelle distincte et relation vers la gravité
2	Base d’objectifs visés	4 objets, dont un accidentel/non malveillant	Catalogue OV avec contrôle de compatibilité méthodologique
2	Base de sources de risque	5 objets ; catégories associées par libellé	Catalogue de sources, séparé de leur évaluation
2	Catégories d’objectif visé	7 catégories, 4 cochées	Taxonomie ; préserver le marqueur sans le surinterpréter
2	Catégories de source de risque	12 catégories, 6 cochées	Taxonomie ; une catégorie cochée n’implique pas un objet SR présent
2	Échelle de motivation	3 niveaux +, ++, +++	Échelle qualitative ordonnée
2	Échelle des ressources	3 niveaux +, ++, +++	Échelle qualitative ordonnée
2	Échelle de pertinence	3 niveaux Faible, Moyenne, Élevée	Résultat configuré ; sélection finale motivée
2	Matrice de niveau de pertinence.png	3×3 ; ressources verticales croissantes, motivation horizontale croissante	Transcription documentée à valider, pas import de données structurées
2	Couples par SR.png	Vue polaire groupée par source ; anneaux de pertinence	Vue dérivée, jamais source canonique des évaluations
2	Couples par OV.png	Vue polaire groupée par objectif, mêmes concepts	Autre regroupement du même jeu de couples
2	Thumbs.db	Cache système	Ignoré, tracé dans le rapport d’import

Les huit échelles réellement observées

Échelle	Ordre observé	Particularité
Intégrité	Négligeable → Limitée → Critique	3 niveaux, ne pas inventer un quatrième
Confidentialité	Public → Interne → Restreint → Confidentiel	4 niveaux locaux
Disponibilité	Négligeable → Limitée → Importante → Critique	Descriptions : > 1 jour ; 4 h–1 jour ; < 4 h ; < 30 min
Gravité	G1 Mineure → G2 Significative → G3 Grave → G4 Critique	Indice ordinal distinct de toute valeur de calcul
Niveau d’impact	Mineure → Significatif → Grave → Critique	Correspondance explicite aux quatre gravités ; conserver le libellé source
Motivation	+ → ++ → +++	Ordre seul ne démontre pas une distance numérique entre niveaux
Ressources	+ → ++ → +++	Même représentation, concept distinct
Pertinence	Faible → Moyenne → Élevée	3 niveaux, pas une gravité de risque

Les couleurs des cellules « Couleur » existent dans le remplissage Excel même quand leur valeur est vide : gravité/impact #009F8F, #F6EB45, #FF9A35, #E73C50 ; pertinence #009F8F, #FF9A35, #E73C50.

Préserver ces valeurs de configuration, en ajoutant texte et contraste accessibles. Les couleurs de l’interface sont indépendantes.

Matrice de pertinence transcrite

Ressources ↓ / Motivation →	1	2	3
3	Moyenne	Élevée	Élevée
2	Faible	Moyenne	Élevée
1	Faible	Faible	Moyenne

La matrice à neuf cellules est observée dans l’image. Ce n’est ni une multiplication ni une prescription universelle ANSSI. Le rayon du cercle représente la pertinence : 3 près du centre, 1 à l’extérieur sur l’illustration source. L’angle regroupe SR ou OV ; il n’est pas une dimension calculée. Les PNG ne donnent pas une table fiable des ressources, motivations, activités ou justifications de chaque couple : ne pas reconstituer ces valeurs depuis les pixels. Les couples seront saisis ou importés d’un export structuré complémentaire.

Points à arbitrer avant import validant

1. **Associations manquantes** : aucune VM renseignée sur les 17 ER ; aucune association mission–VM–support visible. Créer une liste « À rapprocher », ne jamais inventer ces relations.

2. **Disponibilité** : < 30 min est inclus dans < 4 h ; les bornes 4 h, 30 min et 1 jour ne constituent pas une partition explicite. Conserver les descriptions ; demander un arbitrage avant calcul quantitatif.

3. **Accidentel dans SR/OV** : conserver la donnée importée, signaler son incompatibilité avec le parcours de scénarios intentionnels EBIOS ; proposer le socle de sécurité ou un autre parcours pertinent, après décision humaine.

4. **Gravité proposée/retenue** : ces deux champs existent ; aucune formule n’est exportée. Une ressemblance des résultats avec un maximum des impacts ne prouve pas la règle. La cible doit demander une règle publiée ou une appréciation justifiée.

5. **Identités** : codes incomplets et numéros discontinus ne prouvent pas des objets supprimés. Rapprochement explicite par type, organisation, libellé et preuve de décision.

6. **Portée incomplète** : pas de données structurées des ateliers 3–5, de matrice de risque gravité/vraisemblance, d’échelle de vraisemblance ni de workflow complet. Aucun de ces éléments ne doit être présenté comme extrait d’ARM.

Registres et configurations transversales

Registre canonique : déclarer une seule fois

Concept	Source actuelle / cible proposée	Réutilisation et évaluation
Organisation, entité, périmètre	perimeters existe ; grc.organizations proposé seulement pour la propriété/isolation	Une organisation propriétaire n'est pas une copie de tous les périmètres. Liaison explicite avec racines autorisées.
Fournisseur/prestataire	suppliers	SR, partie prenante, support ou responsable référencent le fournisseur ; ne recopient pas sa fiche.
Responsable	roles, utilisateurs serveur et leurs affectations	Sélection d'un rôle dans le périmètre ; pas d'utilisateur créé depuis le nom d'un service ARM.
Processus	processes	Référence pour mission, VM et BIA sans toucher à la cartographie dynamique.
Actif/application/service/support	Registre existant à rechercher ; sinon grc.catalogObjects type asset	Types et catégories configurables ; « support de l'étude » est un rôle de l'actif, pas son doublon.
Mission et valeur métier	grc.catalogObjects types mission, businessValue si absents	Associations à l'étude distinctes ; besoins D/I/C évalués par contexte.
SR et OV	grc.catalogObjects types riskSource, targetObjective	SR réutilisable, motivation/ressources propres au couple dans une étude.
Événement redouté	Type fearedEventTemplate et occurrence d'étude	Le modèle ne porte pas une gravité absolue pour toutes les études.
Partie prenante	Référence à fournisseur/entité/objet existant	Dépendance, pénétration, maturité et confiance appartiennent à l'étude, pas à la fiche fournisseur globale.
Mesure de sécurité	items et référentiels de conformité existants	L'application locale d'une mesure se suit dans riskMgmt.measures/traitements ; ne pas confondre définition et mise en œuvre.
Risque, action, preuve	riskMgmt.risks, findings, evidences	Conserver les identifiants et les liens bidirectionnels ; pas de registres parallèles.

Les bibliothèques génériques peuvent être partagées ; les objets réels restent propriétaires d'une organisation et de périmètres explicites. La publication d'une configuration générique ne publie jamais les évaluations des études qui l'utilisent.

Catalogue de configurations

Les familles sont scale, criterion, taxonomy, matrix, impactProfile, evaluationPolicy, workflow, classification. Chaque famille possède des versions ; une version publiée est immuable. Les états d'activation/archivage sont portés par la famille ou son affectation, pas en réécrivant le snapshot publié.

Une échelle comporte dimensionKey, type qualitatif/quantitatif/hybride, niveaux d'identifiants stables et ordre unique, libellé, description, couleur et éventuellement valeur/unité/bornes. Une valeur numérique n'est jamais déduite de l'ordre. Les bornes ne sont validées qu'après définition explicite des inclusions/exclusions. Des niveaux peuvent être renommés dans une nouvelle version ; les historiques

gardent les anciens libellés.

Un critère référence une version d'échelle et précise l'objet évalué. Une matrice référence deux versions d'échelles d'entrée et une version d'échelle de sortie. Elle stocke chaque cellule explicitement ; le nombre de niveaux peut différer entre dimensions. Les matrices de pertinence SR/OV et de risque gravité/vraisemblance ont des types distincts et ne sont jamais interchangeables.

Pour l'impact ARM, garder trois concepts : catégories d'impact (4), niveaux d'impact (4), profils descriptifs par catégorie/niveau (16). L'association niveau d'impact → gravité est un mapping explicite versionné ; une règle d'agrégation multimpacts ne se déduit pas de ce mapping.

Résolution et héritage proposés

Le « global » est une bibliothèque de modèles approuvés, en lecture ; il ne donne aucun accès aux données d'une autre organisation. Les affectations organisationnelles choisissent une version de modèle. Les affectations de méthode doivent être compatibles avec la version de méthode et l'organisation. Une dérogation d'étude est un fork traçable, soumis aux permissions et à une justification.

Ordre de résolution par clé sémantique : **fork explicite de l'étude → affectation organisation+version de méthode → affectation organisation → défaut de la version de méthode → bibliothèque globale explicitement autorisée**. Il ne s'agit pas de fusionner arbitrairement des JSON : chaque clé résout vers une version entière. Deux candidats au même rang provoquent une erreur de conflit, pas le choix du dernier modifié. Les dépendances de chaque version (axes, niveaux, profils) sont fermées et résolues ensemble.

À la création, calculer le bundle complet, vérifier compatibilité et visibilité, afficher l'origine de chaque version puis figer ses références et empreintes. Une modification de valeur par défaut ne change jamais une étude ouverte. « Adopter une nouvelle configuration » crée une nouvelle révision de contexte, montre les différences, conserve les anciennes évaluations et marque les éléments à réévaluer ; aucun recalcul historique implicite.

Champs libres et sélecteurs

Champ actuel ou export	Cible	Texte conservé
scenario.source	Référence SR + éventuelle référence fournisseur/entité	Description de l'intention et hypothèses
scenario.fearedEvent	Occurrence ER de l'étude	Formulation spécifique et conséquences
scenario.supportingAssets	Multi-sélecteur d'actifs autorisés	Explication de leur rôle
study.method	Version de méthode publiée	Notes sur le choix
study.workshops[0..4]	Livrables et validations par étape	Notes héritées intégrales, sans parsing autoritaire
Responsable/propriétaire ARM	Rôle référencé ou rapprochement à résoudre	Libellé source dans la piste d'import
Catégorie/parent	Taxonomie versionnée, sélecteur hiérarchique	Description et motif de classement
Critère/niveau/gravité	Niveau d'échelle épinglée	Justification de l'évaluation
Impacts ER concaténés	Liste de profils/évaluations contextualisées	Texte original et commentaire
Titres, objectifs d'étude, raisonnement, décisions	Texte encadré	Rester libres : ne pas transformer l'analyse en cases arbitraires

Créer un objet depuis un sélecteur est possible seulement avec le droit de gestion du registre. Sinon proposer une demande ou une valeur « à rapprocher » qui empêche la validation concernée. Aucun accès

par recherche, autocomplétion ou export à un objet non autorisé.

Architecture cible — évolution de legacy

Trois couches et stockage

Schéma : voir la figure d’architecture et la source Markdown pour le diagramme Mermaid.

Phase initiale : garder l’état JSON dans SQLite et l’API /api/state. Ajouter un namespace grc versionné et des adaptateurs vers les registres existants. Aucun deuxième serveur, ORM ou stockage métier concurrent. Le schéma conceptuel n’oblige pas à une refonte SQL. Extraire des services testables dans les modules actuels avant d’envisager des endpoints spécialisés.

Le namespace proposé comprend organizations, catalogObjects, catalogRevisions, relations, configFamilies, configVersions, configAssignments, methodFamilies, methodVersions, studyContexts, stepRuns, observations, scenarioGraphs, importRuns, legacyBindings. Ces noms sont des **ajouts proposés**, pas des collections déjà présentes. Chaque ajout doit être classé pour la projection et la fusion serveur ; ne pas ouvrir le namespace entier aux éditeurs.

Les objets préexistants restent canoniques dans leurs collections : riskMgmt.studies, risks, assessments, policies, decisions, measures, treatments, scenarios, suppliers, roles, perimeters, processes, items, findings, evidences. legacyBindings lie les anciens identifiants aux nouveaux concepts sans remplacer les enregistrements immuables.

Frontières de modules proposées

Fichier à créer ou adapter	Responsabilité
modules/grc-catalog-core.js	Références typées, adaptateurs de registres, rapprochement et relations
modules/grc-config-core.js	Validation de dimensions, matrices, résolution déterministe et bundles
modules/grc-method-core.js	Définitions publiées, compatibilité, étapes, transitions et validations déclaratives
modules/grc-study-core.js	Contexte d’étude, observations, révisions, dépendances et états de revue
modules/grc-shared-ui.js	Sélecteurs accessibles, niveaux, origine des configurations, historique
modules/grc-admin-ui.js, modules/ebios-study-ui.js	Administration et parcours, sous les routes de l’application actuelle
legacy_grc.py	Autorisations, intégrité référentielle, validation des versions et règles métier côté serveur
legacy_server.py	Projection/fusion, persistance atomique, audit, contrôle de concurrence
legacy_risks.py, modules/risk-core.js	Adaptation de versions d’évaluations, sans changement rétroactif
modules/integration-core.js	Exposition des nouveaux types et fournisseurs dans le catalogue de références

Les noms définitifs doivent suivre les conventions du dépôt au SHA d’implémentation. Les tests du moteur pur et du validateur serveur utilisent les mêmes fixtures ; le client n’est jamais l’autorité du calcul ou des permissions. Aucune règle exécutable arbitraire (eval, script fourni par admin) dans les configurations : utiliser une liste fermée d’opérateurs validés (manual, lookupMatrix, explicitMapping, puis agrégations autorisées et documentées).

Droits et frontières organisationnelles

Réutiliser permission, canValidate, rôles et périmètres ; ajouter des capacités explicites si nécessaire, avec migration restrictive : consulter les registres ; gérer les objets ; gérer les brouillons de configuration ; publier une version ; modifier une étude ; valider une étape ; accepter un risque. canValidate ne suffit pas, à lui seul, à ouvrir toutes les administrations.

Chaque objet non générique porte organizationId et des perimeterIds. Toute référence vérifie l'organisation, la visibilité de l'objet et la couverture du périmètre métier ; le droit de consulter un parent n'autorise pas à éditer une configuration héritée. Les configurations globales excluent les données réelles et ne sont modifiables que par une capacité dédiée. Le mode initial est mono-organisation explicite ; l'ouverture multi-organisation reste bloquée tant que les tests d'isolation ne passent pas.

Contrôler aussi les historiques, snapshots, journaux d'import, compteurs de dépendances, exports et résultats de recherche. Un compteur « utilisé par N études » n'affiche que les dépendances autorisées ; la désactivation tient compte de toutes les références côté serveur sans révéler leurs titres. L'administration actuelle donne accès à l'état complet : toute future séparation entre administrateur système et administrateur d'organisation nécessite une règle serveur nouvelle, pas un simple filtre UI.

Concurrence et audit

Toute mutation métier suit : authentification/CSRF → contrôle de version d'état → fusion de la projection autorisée → validation des références et permissions → validation des invariants → écriture et audit dans une transaction → retour de la nouvelle projection. Rejeter les publications ou validations concurrentes ; proposer rechargement et réapplication explicite du brouillon. Garantir l'atomicité du contrôle de version et de l'écriture (transaction SQLite adaptée ou mise à jour conditionnelle), y compris entre requêtes simultanées.

L'auteur et l'horodatage sont attribués par le serveur. Une modification de configuration publiée produit une nouvelle version ; une modification d'objet produit une révision consultable. Les snapshots d'étude enregistrent la révision de chaque objet utilisé pour pouvoir restituer son nom et son contexte historiques sans copier un nouveau fournisseur.

Contrats de données et de services proposés

Enveloppes et identités

Identifiant opaque stable, distinct du code de présentation, du numéro de ligne et du libellé. Référence typée : {kind, id, revisionId?} ; kind vient d'une liste de types reconnus, jamais d'un chemin libre dans l'état. La portée est explicite : organizationId, perimeterIds. Une référence globale n'est permise que pour une configuration ou un modèle générique approuvé, jamais pour un objet réel par défaut.

Chaque nouvelle collection mutable possède id, schemaVersion, createdAt, createdBy, updatedAt, revision, status, portée et piste d'audit serveur. Chaque version publiée possède familyId, version, previousVersionId, sourceVersionId?, publicationReason, publishedAt, publishedBy, contentHash et dépendances exactes. L'empreinte couvre une sérialisation canonique du contenu et des références ; l'ordre des tableaux sémantiques est conservé, celui des clés d'objets normalisé. Ne pas utiliser la présentation HTML comme source du hash.

Entité	Champs métier principaux	Invariants
CatalogObject / CatalogRevision	type, nom, catégories, propriétaire référencé, attributs autorisés	Pas de doublon automatique ; révision historique stable ; archivage si référencé
Relation	sujet, prédicat, objet, contexte optionnel	Types compatibles, même portée ou partage explicite, pas de cycle pour un parent
ScaleVersion	dimensionKey, mode, niveaux	IDs/ordres uniques ; numérique optionnel ; unité obligatoire si valeur quantitative
CriterionVersion	clé, type d'objet évalué, scaleVersionId, justificationRequired	Domaine compatible ; ne pas confondre critère et niveau
MatrixVersion	rowScaleVersionId, columnScaleVersionId, resultScaleVersionId, cells	Une cellule pour chaque paire exacte ; aucun ID étranger ni doublon
ConfigAssignment	clé, versionId, rang, organizationId, methodVersionId?, studyId?	Une affectation applicable par clé et rang ; origine traçable
MethodVersion	code, provenance, étapes, inputContracts, configSlots, resultContracts	Dépendances explicites ; moteur/opérateurs autorisés ; publication testée
StudyContext	studyId, revision, methodVersionId, configBindings, registrySnapshots, reason	Bundle résolu immuable ; étude et références autorisées ; pas de référence « latest »
StepRun	studyId, contextId, stepKey, state, validationRefs	Incomplétude visible ; validation serveur ; réouverture justifiée invalide les validations dépendantes
Observation	kind, studyId, contextId, subjectRefs, values, justification, sourceRefs	Évaluation de besoin/ER/couple/partie prenante ; pas un nouveau registre central de risques
ScenarioGraph	scenarioId, contextId, nodes, edges, paths	IDs stables, références de livrables ; variantes explicites, pas de lien libre vers un objet interdit
ImportRun	sourceHash, parserVersion, mappings, decisions, stateVersion, report	Rejouable/idempotent ; original conservé localement ; aucune publication automatique

Risque et évaluation finale

Le risque reste dans riskMgmt.risks. Le résultat final d'une analyse reste dans riskMgmt.assessments ; ne pas ajouter une seconde collection de risques/évaluations concurrente. Les observations intermédiaires n'ont pas le statut de risque validé.

Les enregistrements historiques sans schemaVersion sont interprétés comme version 1. Leur policyId et leurs snapshots restent inchangés. Introduire une version 2 additive pour les nouvelles évaluations seulement : schemaVersion:2, studyId, studyContextId, methodVersionId, riskId, stage, dimensionValues (références de niveaux), result (résultat typé), justification, scenarioIds, proofRefs, auteur/date serveur. Une politique v1 compatible conserve son policyId; un bundle multiméthode remplace l'hypothèse obligatoire « impact×vraisemblance » dans le validateur v2. Ne pas forcer toute méthode personnalisée dans deux dimensions v1.

Pour une matrice de risque, result contient resultScaleVersionId et levelId. Pour une appréciation manuelle ou quantitative, le type et les contraintes viennent du contrat de méthode publié. Les vues historiques utilisent l'adaptateur v1 ; les vues de comparaison groupent par contexte compatible. Aucune moyenne ou classement commun entre échelles hétérogènes sans correspondance explicite validée. riskMgmt conserve son schéma de conteneur tant qu'une migration de conteneur n'est pas nécessaire ; documenter indépendamment la version de chaque enregistrement.

Matrice et interprétation

cells contient {rowLevelId,columnLevelId,resultLevelId}. Axe vertical croissant vers le haut, horizontal croissant vers la droite : l'orientation est une propriété d'affichage, le calcul utilise les IDs. Le schéma JSON fourni décrit le **contrat de bundle échelles/matrices/contexte**, pas tout le modèle métier ; les invariants interobjets nécessitent un validateur sémantique supplémentaire.

L'annexe de pertinence contient les neuf correspondances lues dans le PNG. L'exemple synthétique de contrat est une fixture à visée technique, pas une configuration déjà publiée dans l'application.

Services métier internes à créer

Opération	Entrée	Résultat / erreurs attendues
resolveConfig	organisation, périmètres, version méthode, forks explicites	bundle et provenance ; AMBIGUOUS_ASSIGNMENT, INCOMPATIBLE_DIMENSION, FORBIDDEN_REFERENCE
publishConfigVersion	draftId, expectedRevision, raison	version figée ; INVALID_MATRIX, DEPENDENCY_NOT_PUBLISHED, STALE_REVISION
createStudyContext	studyId, methodVersionId, bindings, expectedStateVersion	contexte révisé ; UNRESOLVED_REFERENCE, SCOPE_MISMATCH
evaluateObservation	contexte, sujets, valeurs, justification	proposition calculée + décision humaine distincte ; UNKNOWN_LEVEL, MISSING_JUSTIFICATION
validateStep	contexte, étape, expectedRevision	validation signée ; liste de prérequis manquants si refus
prepareImport	fichier local, organisation cible, profils	rapport sans mutation métier ; correspondances candidates explicables
commitImport	importRunId, décisions de rapprochement, expectedStateVersion	transaction atomique ; refuse ambiguïtés bloquantes et import concurrent

Ces services ne sont **pas des endpoints existants**. Dans le premier lot, les commandes transitent par la sauvegarde /api/state actuelle et sont revalidées côté serveur. Si des endpoints dédiés sont ajoutés ensuite, définir un contrat HTTP versionné, les mêmes contrôles et des erreurs 400/403/409/422 documentées avant leur usage ; ne pas faire croire qu’ils existent déjà.

Parcours et moteur multiméthode

Moteur commun, sens métier distinct

Une méthode publiée référence ses étapes, leurs entrées/sorties typées, ses configurations et ses validateurs. Elle peut réutiliser sélecteurs, matrices, preuves et décisions. Elle ne récupère pas automatiquement les cinq ateliers EBIOS. Un formulaire rendu depuis un JSON ne suffit pas : les contraintes de cohérence propres à chaque méthode sont validées côté serveur.

Cycle d'étude proposé : Brouillon → En cours → En revue → Clôturée → Archivée. L'adaptateur conserve les états historiques existants (En cours, Clôturée, Archivée) ; les états supplémentaires exigent une évolution explicite des validateurs. Les étapes peuvent être revisitées ; une modification amont déclenche « À revoir » en aval, sans détruire les anciens livrables ni recalculer une décision. La clôture n'efface pas les risques suivis.

EBIOS RM : cinq ateliers, livrables et validations

Les intitulés et la démarche sont issus du guide ANSSI v1.5. Les règles de complétude UI ci-dessous sont des **propositions d'application**, pas des exigences normatives universelles.

Atelier	Entrées et actions	Livrables liés	Validation proposée
1 — Cadrage et socle de sécurité	Cadre, participants, cycles, missions, VM, supports, besoins, ER, socle et écarts	Contexte ; associations VM/support ; ER évalués ; référentiels et écarts	Périmètre explicite, objets rapprochés, gravités justifiées, exceptions documentées
2 — Sources de risque	SR/OV réutilisables ; couples ; motivation, ressources et activité ; pertinence ; sélection	Observations par couple ; proposition calculée si matrice publiée ; décision retenu/non retenu	Intentionalité compatible, justification de sélection, références VM/ER pertinentes
3 — Scénarios stratégiques	Parties prenantes de l'écosystème ; caractérisation ; chemins stratégiques ; mesures sur l'écosystème	Évaluations contextuelles des parties prenantes ; scénarios stratégiques liés SR/OV et ER	Traces entre sources, objectif, chemin et conséquences ; hypothèses explicites
4 — Scénarios opérationnels	Déclinaison des scénarios stratégiques ; actions élémentaires ; modes opératoires ; vraisemblance	Graphes et variantes ; évaluations de vraisemblance selon l'échelle choisie	Chaque variante reliée à son scénario ; étapes et vraisemblance justifiées
5 — Traitement du risque	Synthèse, stratégie, mesures, risque résiduel et surveillance	Évaluations du registre ; plans/actions/preuves ; décisions d'acceptation ; réexamens	Décideur habilité, mesure appliquée ou hypothèse distinguée ; réévaluation explicite

L'échelle d'activité et celles de dangerosité/vraisemblance ne sont pas dans l'export ARM. Les rendre configurables à partir de sources validées avant de les activer ; ne pas les compléter silencieusement. Les durées des cycles sont à choisir, pas à inventer depuis les cellules vides.

Le guide recommande d'apprécier motivation, ressources et activité (p. 38). La matrice ARM motivation×ressources est une configuration locale. L'activité peut être un critère documenté distinct ; elle ne devient pas un multiplicateur caché. La décision de retenir un couple reste explicite avec motif, y compris lorsqu'elle diffère d'une suggestion issue de la pertinence.

Le guide articule socle de sécurité pour les risques courants, accidentels/environnementaux et scénarios intentionnels avancés (p. 4). Un OV accidentel importé est conservé mais signalé : il ne doit pas être validé automatiquement comme objectif d'un attaquant dans l'atelier 2. L'icône incendie illustre un événement ou une catégorie adaptée, jamais une intention inventée.

Représentations demandées

Suivi ligne par ligne : une ligne par objet évalué dans un contexte (couple en A2, risque en synthèse A5). Colonnes adaptables au type : SR, OV, VM/ER, dimensions, proposition, retenu, justification, propriétaire, état. La sélection pilote les panneaux inférieurs. Une multisélection affiche son nombre et ses références ; zéro sélection ne supprime aucune donnée.

Matrice : en A2, ressources×motivation→pertinence (3×3 ARM). En synthèse, gravité×vraisemblance→niveau de risque selon la politique publiée. Titre, axes, légende et version toujours visibles. La matrice de risque 4×4 de la maquette précédente est une proposition distincte ; elle n'est pas issue de cet export.

Cercle : groupement SR ou OV des couples ; anneaux par pertinence (élevée vers le centre pour la référence ARM), avec liste textuelle équivalente. En synthèse A5, ne pas réutiliser ce cercle en l'intitulant « risque » sans définir une autre sémantique. Afficher le contexte exact et les cas non évalués séparément.

Scénario visuel : colonnes Connaître / Rentrer / Trouver / Exploiter pour la vue opérationnelle inspirée du guide ; alternatives de chemins sélectionnables, transitions directionnelles animées, contour renforcé des nœuds sélectionnés, fond atténué des autres chemins. Animation CSS de flux sur un tracé SVG orienté ; prefers-reduced-motion fige le mouvement tout en conservant flèches et sélection. Le modèle de graphe permet des scénarios plus riches : ne pas imposer quatre étapes à toute méthode ou toute attaque.

ISO/IEC 27005

Méthode paramétrable : contexte et critères ; identification ; analyse ; évaluation ; traitement ; acceptation et suivi, avec communication/consultation et revue. Cette séquence est une proposition de structuration de l'application ; ce dossier ne prétend pas reproduire le texte intégral de la norme ni en certifier la conformité. Consigner l'édition de référence retenue et les documents autorisés lors du cadrage métier.

Réutiliser risques, actifs, événements, évaluations, mesures et décisions. Ne pas rendre obligatoires les couples SR/OV, les ateliers EBIOS ou les colonnes du graphe opérationnel pour cette méthode. La comparaison des résultats dépend de critères compatibles publiés, jamais du seul libellé « ISO 27005 ».

Personnalisée et MÉHARI

L'éditeur de méthodes personnalisées choisit les types d'objets, étapes, critères, configurations, justifications requises, validations et sorties. Les conditions restent déclaratives et limitées à des opérateurs autorisés ; prévisualisation et tests avant publication. Une méthode en brouillon ne crée pas d'étude validable.

MÉHARI existe comme méthode déclarée dans legacy. Préserver ses études et évaluations via un adaptateur legacy-declared ; ne pas promettre un moteur MÉHARI complet ni convertir ses données en EBIOS. Une extension complète nécessite ses propres sources et contrats.

Spécifications graphiques et composants

Référence conservée

Style 08 : barre latérale forêt, fond clair chaud, cartes blanches, accents sauge et turquoise, signature marine discrète. Garder les pictogrammes colorés et les chevrons de dépliage des menus. Ne pas remplacer les menus par une seconde application. Les vues du dossier sont des illustrations synthétiques de la cible, isolées du runtime.

Tokens proposés : fond #F5F5F0, carte #FFFFFF, bordure #DCE2DB, forêt #103F33, sidebar #123E32, ligne active #275647, texte #173F34, secondaire #52645E, turquoise #00A8B0, marine #142F61, focus #326899. Le turquoise d'accent n'est pas utilisé comme texte fin sur blanc : utiliser une variante foncée ou une bordure, vérifier les contrastes. La famille claire/sauge s'applique à tous les utilisateurs depuis Administration ; le thème n'altère pas les couleurs métier des niveaux.

Risques et conséquences : rouge ; valeurs métier : violet ; SR : orange ; parties prenantes : bleu ; mesures : vert. Les icônes sont accompagnées d'un libellé ; ni la couleur ni un emoji seuls ne portent une signification. Utiliser les icônes SVG existantes ou une bibliothèque déjà présente, avec étiquette accessible. Hacker/voleur illustrent une source intentionnelle ; incendie représente un événement adapté, pas un objectif d'attaque présumé.

Navigation cible — affinée au chapitre 12

- Administration → Configuration GRC : échelles, critères, catégories, matrices, profils, méthodes, affectations, versions et dépendances.

- Registres : listes existantes exposées par adaptateurs ; nouveaux registres seulement pour les concepts absents.

- Gestion des risques → Études : assistant, parcours de méthode, suivi, scénarios, traitement et historique.

- Import ARM : préparation locale, rapprochement, anomalies, aperçu et validation ; aucun import automatique depuis une simple capture.

Les vues Administration/Apparence et Configuration sont distinctes. Masquer ou désactiver les actions selon les capacités renvoyées par le serveur ; un masquage UI n'est pas une autorisation.

Dix vues livrées

Galerie HTML ; captures PNG et planche dans le dossier graphique.

1. Registres partagés : types, source canonique, recherche et usages.

2. Configurations : origine, version, affectation et dépendances.

3. Échelle : niveaux ordonnés, couleurs, valeurs facultatives et publication.

4. Matrice de pertinence : neuf cellules, axes et sources de version visibles.

5. Nouvelle étude : sélection de méthode, périmètres et bundle avant création.

6. Atelier 1 : mission → VM → support, ER et besoins liés.

7. Atelier 2 : suivi en lignes, cercle et matrice coordonnés.

8. Scénario opérationnel : variantes, flux directionnels et nœuds renforcés.

9. Import ARM : comptes observés, anomalies et décisions de rapprochement.

10. Historique : comparaison, études utilisatrices et réévaluation explicite.

Ces vues complètent les maquettes EBIOS des cinq ateliers déjà présentes ; elles ne les remplacent pas et ne marquent aucune proposition « validée » sans décision utilisateur.

Contrats UI partagés

Composant	Comportement et états
ReferencePicker	Recherche par type/portée ; sélection par ID ; état vide, chargement, interdit, archivé ; création sous droit dédié
LevelPicker	Niveaux de la version épinglée ; ordre visible, texte + couleur ; aucune valeur numérique implicite
MatrixViewer/Editor	Dimensions variables ; cellule clavier ; liste équivalente ; édition seulement en brouillon ; conflit et cellules manquantes explicites
ProvenanceBadge	Global/organisation/méthode/étude, famille, version et date ; lien vers dépendances autorisées
AssociationEditor	Relations typées ; signalement des liens manquants ; pas d’auto-déduction par nom
JustificationField	Obligatoire selon contrat ; brouillon conservé en cas d’erreur ; échappement du contenu
HistoryDiff	Avant/après et auteur/date ; changements de règle séparés des changements de libellé ; anciennes versions lisibles
RiskTable + LinkedPanels	Sélection stable par ID ; filtres annoncés ; matrice/cercle synchronisés ; état non évalué distinct
ScenarioGraph	Chemins navigables clavier ; sélection sans effacer les autres ; flux orienté ; version textuelle du chemin
StudyWizard	Prévisualise bundle et références ; bloque les ambiguïtés ; ne publie pas automatiquement une configuration

Accessibilité cible : focus visible, navigation clavier, aria-expanded sur chevrons, boutons réels, titres structurés, contraste contrôlé WCAG AA, pas de dépendance à la couleur seule, mouvement réduit respecté. À 1280 px, table puis deux panneaux ; sous 900 px, panneaux empilés et défilement horizontal explicite pour tables/graphes. Tester zoom 200 %, contenu long et lecteurs d’écran sur le code intégré. Les captures desktop ne constituent pas cette recette.

La navigation simplifiée, ajoutée après analyse de la vidéo, précise et remplace l’organisation sommaire de cette section. Les dix vues illustrent désormais les sept rubriques métier et Administration séparée.

Import ARM et migration des historiques

Import en deux temps

1. Préparer un espace temporaire local ; inspecter l’archive sans exécuter son contenu. Refuser chemins absolus/traversées, liens symboliques, archive chiffrée, nombre/taille décompressée excessifs et formats inattendus ; fixer les limites dans une configuration d’exploitation. Ignorer Thumbs.db avec motif tracé.

2. Lire XLSX sans exécuter de formule, macro ou lien externe. Conserver les valeurs source et adresses de cellules dans la piste privée. Les classeurs fournis n’ont pas de formule ; traiter le cas futur explicitement.

3. Extraire schéma, couleurs de remplissage, groupes de cellules fusionnées et marqueurs. Décoder _x000D_ uniquement dans la valeur normalisée ; garder le texte brut. Pour la feuille des missions, lire les neuf ancres de mission et leurs groupes, pas 89 objets.

4. Présenter un mapping des colonnes et le type cible ; associer l’organisation et les périmètres. Créer des candidats de rapprochement explicables ; aucun rapprochement par nom seul entre organisations.

5. Importer d’abord taxonomies/échelles, puis critères/profils, objets, contexte et évaluations. Les versions importées restent en brouillon jusqu’à validation de leur sens, portée et provenance. Les identifiants cibles sont générés ; les codes ARM deviennent des identifiants externes qualifiés.

6. Résoudre les propriétaires, hiérarchies et références. Conserver les ambigus en file de rapprochement ; autoriser la sauvegarde du brouillon sans autoriser la validation du livrable incomplet.

7. Les PNG sont des pièces de référence privées. La matrice transcrite est préremplie dans un brouillon explicitement « transcription manuelle à valider ». Ne pas créer les évaluations individuelles de couples depuis les positions du cercle.

8. Exécuter un dry-run : créations, correspondances, éléments ignorés, erreurs, avertissements, versions et permissions. Confirmer les décisions métier dans l’application ; écrire atomiquement, avec rapport et auteur serveur.

Clé d’idempotence : organisation cible + empreinte archive + version du parseur + profil d’import et décisions normalisées. À rejouer, retourner le rapport existant ou une nouvelle révision justifiée ; ne pas doubler les objets. Une modification des mappings produit un nouvel aperçu avant écriture.

Le rapport public expose seulement structures/comptes/erreurs génériques. Les valeurs originales, noms d’études et pièces restent dans le stockage local protégé, jamais dans Git ou les captures de démonstration.

Mapping historique legacy

- Préserver exactement les collections canoniques et les objets immuables. Créer des legacyBindings vers des versions de configuration correspondant aux politiques existantes ; une déduplication éventuelle ne doit pas modifier policyId des évaluations.

- Créer un contexte d’étude hérité documenté, sans prétendre connaître une version de méthode qui n’était pas enregistrée. Utiliser un adaptateur legacy-declared et un niveau de complétude explicite.

- Conserver workshops comme notes originales. Proposer une saisie structurée complémentaire ; aucun découpage automatique ne vaut validation métier.

- Garder les anciens champs de scénario pour lecture/export ; ajouter des liaisons structurées à côté. Une suppression des champs historiques nécessite une migration séparée et une preuve de compatibilité.

- Pour les nouvelles évaluations v2, conserver la collection centrale et faire évoluer les validateurs/exporteurs par version. Un ancien lecteur incompatible doit être refusé explicitement, jamais recevoir un résultat tronqué présenté comme complet.

Déploiement de migration proposé

Avant toute migration réelle : sauvegarde locale de SQLite et des pièces, inventaire du nombre d’objets/liens, empreintes des évaluations/politiques/décisions, test de restauration sur copie. Aucun jeu réel n’est envoyé à GitHub.

Un script déterministe prépare un rapport ; la migration s’exécute dans une transaction, avec numéro de schéma et journal. Tester deux exécutions identiques, panne avant commit, conflit de version et rollback. Après commit, vérifier les empreintes des objets historiques, les liens Annex A, les risques de référence, les fichiers, les périmètres et les exports.

Le rollback restaure sauvegarde et version applicative compatibles ensemble ; ne pas rétrograder uniquement le code sur un état v2. Tant que le lot n’est pas validé, un indicateur fonctionnel garde le nouveau parcours désactivé ; les pages historiques restent utilisables. L’activation multi-organisation et la publication des configurations importées sont des étapes distinctes.

Plan technique par lots vérifiables

L’IA d’implémentation travaille exclusivement sur sa branche dédiée, fondée sur origin/legacy. Chaque lot produit un commit révisable, sa documentation et les tests effectivement exécutés. Ne pas modifier legacy, fusionner ou déployer. Les fichiers de cartographie dynamique restent exclus.

Lot	Modifications concrètes	Porte de sortie
0 — Revalidation et sauvegarde	Comparer SHA audité et SHA courant ; inventorier registres et formulaires suivis ; relever les tests disponibles ; préparer copie de données synthétique et migration	Rapport factuel, absence de doublon canonique, frontières organisationnelles décidées
1 — Socle et permissions	Namespace grc, schémas, références typées, adaptateurs ; legacy_grc.py, projection/fusion serveur, audit ; pas d’ouverture UI publique prématurée	Tests inter-organisations/périmètres, rejet IDs interdits, historiques et concurrence
2 — Configurations	Échelles/taxonomies/critères/matrices/profils, versions immuables, affectations, dépendances, résolution ; administration et composants partagés	9 cellules ARM exactes, tailles variables, ordre ≠ valeur, conflits et forks testés
3 — Registres et import	Réutiliser fournisseurs/rôles/processus ; ajouter uniquement types absents ; import dry-run et rapprochement ; objets/revisions/relations	25 fichiers classés, 9 missions, 8 échelles, aucun lien absent inventé, réimport sans doublon
4 — Méthodes et études	Registre de méthodes, version publiée, assistant/bundle, contextes révisés, notes héritées, adaptateurs v1	Création EBIOS et personnalisée sans couplage forcé ; MÉHARI historique intact
5 — EBIOS ateliers 1–2	Objets/relations/observations, besoins et ER, couples/pertinence/activité, tableau et panneaux liés	Parcours complet A1–A2, décision humaine, cas accidentel signalé, sélections cohérentes
6 — EBIOS ateliers 3–5	Écosystème/scénarios, graphe, vraisemblance, évaluation centrale v2, mesures/actions/preuves/décisions/surveillance	Étude de bout en bout synthétique, résiduel explicite, permissions de validation, mouvement réduit
7 — Autres méthodes	Parcours ISO documenté après choix d’édition ; éditeur personnalisé contrôlé ; exports par version	Méthodes sans SR/OV obligatoires, résultats typés, configurations compatibles
8 — Généralisation	Navigation, thème global clair/sauge, usages transversaux volontaires PCRA/conformité, accessibilité, recette et packaging	Tests de non-régression, migration/restauration, dossier à jour ; aucune activation automatique

Les lots 1–2 précèdent l’import validant et toute création d’étude nouvelle. Les ateliers 3–5 n’attendent pas de fausses données ARM : utiliser des fixtures synthétiques et les sources méthodologiques. Les choix non confirmés de calcul empêchent la publication concernée, pas le travail indépendant sur le socle.

Contrôles existants à réutiliser

tests/risk.test.cjs, tests/server_risk_test.py, tests/integration.test.cjs, tests/browser-risks.cjs ; vérifier leurs commandes, dépendances et prérequis au SHA de travail avant exécution. Ajouter des tests au bon niveau, pas des assertions qui recopient simplement le code. Les tests de maquette dans fonctionnalites/ebios-rm/tests/ restent des tests de prototype, distincts des tests métier.

Compte rendu exigé par lot

Liste des fichiers modifiés ; schémas/migrations introduits ; données préservées ; tests avec commande, résultat, SHA et limites ; captures synthétiques ; problèmes et décisions restantes. Ne pas écrire « complet » si une étape est simulée, si les permissions sont seulement UI ou si les liens ne persistent pas après rechargement.

Recette d’implémentation à exécuter

Cette recette décrit les tests du futur code. Elle ne prétend pas qu’ils sont déjà passés. Les seuls contrôles exécutés sur le présent dossier sont consignés dans VERIFICATIONS.json.

ID	Scénario	Résultat exigé
DAT-01	Lire les 21 classeurs et les 3 PNG, classer le cache	Inventaire 25 ; feuilles et colonnes tracées ; zéro formule exécutée
DAT-02	Importer la feuille de missions fusionnées	9 missions, pas 89 ; aucune VM/support inventé
DAT-03	Importer deux fois avec les mêmes décisions	Aucun doublon ; rapport et liaisons stables
DAT-04	Responsable ambigu, parent manquant, libellé identique hors organisation	À rapprocher ; aucune association silencieuse
CFG-01	Échelle d’intégrité 3 niveaux et confidentialité 4	Aucun alignement forcé ; valeur numérique facultative
CFG-02	Évaluer les neuf couples ressources/motivation	1/1 faible, 1/2 faible, 1/3 moyenne ; 2/1 faible, 2/2 moyenne, 2/3 élevée ; 3/1 moyenne, 3/2 élevée, 3/3 élevée
CFG-03	Cellule absente/dupliquée, ID étranger, axe incompatible	Publication refusée avec emplacement précis
CFG-04	Publier v2 puis consulter étude épinglée v1	Résultats/échelles/labels v1 inchangés ; adoption explicite seulement
CFG-05	Deux affectations au même rang ; fork étude	Conflit bloquant ; fork traçable et autorisé, origine intacte
CFG-06	Matrice rectangulaire 3×4 ; méthode sans matrice	Rendu/calcul conformes au contrat, aucune grille 4×4 imposée
SEC-01	Organisation A tente lecture/recherche/export/liaison vers B	Refus serveur, pas de libellé/snapshot/compteur divulgué
SEC-02	Éditeur modifie une configuration héritée ou un objet hors périmètre	Refus serveur ; objets cachés préservés par fusion
SEC-03	Client forge auteur, validation, résultat calculé ou niveau	Recalcul/validation serveur, auteur réel, rejet des falsifications
SEC-04	CSRF absent, session expirée, utilisateur lecteur	Aucune mutation ; saisie locale récupérable sans exposition
SEC-05	Historique, dépendances et rapport d’import avec référence interdite	Projection restrictive jusque dans les détails
EBI-01	Étude synthétique : mission/VM/support → ER → couple → stratégique → opérationnel → traitement	Traçabilité complète, liens persistants après rechargement
EBI-02	Activité non renseignée et OV accidentel dans le parcours intentionnel	Manques explicites et revue humaine ; aucun calcul/choix inventé
EBI-03	Sélection ligne/cellule/cercle puis aucun résultat	Même ensemble d’IDs, filtres visibles, état vide exact
EBI-04	Sélection des trois chemins au clavier	Flèches orientées, nœuds renforcés, équivalent textuel, mouvement réduit respecté

ID	Scénario	Résultat exigé
EBI-05	Clôturer une action sans réévaluation	Risque résiduel inchangé, aucune acceptation automatique
EBI-06	Accepter un risque sans droit puis avec droit et justification	Refus puis décision immuable liée à l’évaluation exacte
MET-01	Étude personnalisée sans SR/OV et résultat qualitatif	Aucun atelier EBIOS imposé
MET-02	Ouvrir les études historiques des quatre méthodes	Lecture/export possibles, aucune conversion arbitraire
MIG-01	Migration sur copie, seconde exécution, interruption, restauration	Idempotence, atomicité, retour prouvé vers version compatible
MIG-02	Comparer hashes des anciennes évaluations/politiques/décisions	Identiques ; codes de présentation gérés selon règles historiques
CON-01	Deux publications/validations concurrentes sur même version	Une seule écriture acceptée ; autre rejetée sans écrasement
REG-01	Lien risque ↔ Annexe A et plan de traitement après migration	Bidirectionnel intact ; conformité non déduite
REG-02	Cartographie dynamique avant/après	Fichiers protégés inchangés, mêmes routes/interactions et données
REG-03	Audits, preuves, PCRA, tâches récurrentes, plans d’action	Scénarios existants passent ; aucun nouveau registre concurrent
EXP-01	Export historique v1 et nouvelles données v2	Ancien format préservé ; extension v2 documentée et sans perte silencieuse
UX-01	Zoom 200 %, clavier, lecteur d’écran, écran étroit	Aucun contrôle inaccessible ; légendes et équivalents textuels présents
UX-02	Changer le thème global depuis un compte autorisé	Tous les utilisateurs concernés, sans modifier couleurs des niveaux

Parcours manuel de référence

Sur un jeu **FICTIF** : créer une organisation/périmètre autorisé et choisir une version de méthode ; sélectionner une VM et un support ; évaluer un ER ; sélectionner SR et OV puis motivation/ressources/activité ; justifier la sélection du couple ; construire un scénario stratégique et sa variante opérationnelle ; choisir une politique de vraisemblance/gravité publiée ; enregistrer l’évaluation centrale ; lier une mesure Annexe A et une action existante ; constater l’application avec preuve ; créer une nouvelle évaluation résiduelle ; prendre une décision habilitée et planifier la revue. Recharger à chaque étape clé. Modifier ensuite une configuration : constater que l’étude conserve sa version jusqu’à adoption explicite.

Navigation ajoutée après la vidéo

NAV-01 : toutes les destinations recensées ont une cible, sans orphelin. NAV-02 : comptes et rôles ont chacun une destination principale et des alias compatibles. NAV-03 : lecteur/éditeur/admin gardent leurs accès autorisés. NAV-04 : tâches récurrentes, actions contextuelles, preuves et cartes restent accessibles. NAV-05 : clavier, chevrons, retour et préférences fonctionnent ; aucune modification interne des cartes. Voir les scénarios détaillés du chapitre 12.

Décisions, incertitudes et sources

Choix retenus pour la proposition

1. Évolution de legacy et stockage existant ; namespace additionnel et adaptateurs, pas de réécriture autonome.

2. Risques, évaluations finales, politiques historiques et décisions restent dans leurs registres actuels.

3. Référentiels transversaux à portée explicite ; configuration publiée immuable, contexte d'étude épinglé.

4. Import ARM préparatoire et contrôlé ; les barèmes observés sont locaux, jamais attribués par défaut à une norme.

5. Style 08, deux variantes globales d'apparence, icônes colorées, chevrons ; cartographie dynamique protégée.

6. L'IA de codage travaille uniquement sur sa propre branche. Le présent travail documentaire est livré sur legacy conformément aux instructions utilisateur.

Questions courtes à poser au moment où elles bloquent un lot

Décision	Question	Travail possible en attendant
Organisation propriétaire	« Une installation correspond-elle à une seule organisation indépendante ? »	Socle mono-organisation explicite, sans activer le partage inter-organisations
Barèmes importés	« Publie-t-on les échelles ARM telles quelles, après revue ? »	Import en brouillon, aucune version activée
Disponibilité	« Quelles bornes exactes pour 30 min, 4 h et 1 jour ? »	Conserver les descriptions qualitatives
Agrégation impacts	« Quelle règle approuvée donne la gravité proposée ? »	Appréciation manuelle justifiée, pas de maximum implicite
Accidentel	« Classe-t-on les cas accidentels dans le socle de sécurité ? »	Conserver et signaler les cas, sans les valider comme attaques intentionnelles
Ateliers absents	« As-tu un export structuré des ateliers 3 à 5 ? »	Implémentation sur fixtures fictives et guide officiel ; aucun remplissage réel
ISO 27005	« Quelle édition et quel parcours interne faut-il appliquer ? »	Contrats génériques et adaptateur historique, pas d'allégation de conformité
Données réelles	« Quels objets existants correspondent aux missions/VM/supports importés ? »	File de rapprochement, relations non validées

Ces décisions ne bloquent pas la réalisation du dossier. L'agent de codage pose seulement la question nécessaire au lot concerné et continue les tâches indépendantes. Ne pas demander une confirmation pour chaque changement réversible déjà autorisé.

Sources et degré d'autorité

- **Code suivi par Git**, SHA 472a81fe315ac323d75a59db74e16b8d39a5b0e8 : fichiers cités dans le diagnostic. Preuve de l'existant technique, pas des données installées chez l'utilisateur.

- **Export ARM.zip**, reçu de l'utilisateur : 25 fichiers inventoriés en annexes. Preuve des valeurs exportées et de représentations, pas d'une règle cachée ou d'un schéma complet. Les données sources restent privées.

- **Prompt de refonte structurelle fourni par l’utilisateur**, 16 sections : exigences traduites dans annexes/exigences.csv. Le livrable demandé ici est le dossier de préparation, pas l’exécution de toute l’implémentation.

- **ANSSI, EBIOS Risk Manager, guide v1.5, septembre 2024, ANSSI-PA-048** : page officielle, PDF officiel. Version indiquée dans le document consulté. Numéros de pages ci-dessous = pagination imprimée, généralement +2 dans le lecteur PDF.

Sujet	Pages imprimées du guide
Socle et risques accidentels / scénarios intentionnels	4
Démarche itérative et cinq ateliers	6–11
Cadre, périmètre, ER, socle de sécurité	18–31
Sources, objectifs, pertinence, sélection	34–39, en particulier 38
Écosystème, scénarios stratégiques, mesures	42–55
Scénarios opérationnels et graphes	58–64
Vraisemblance	65–67
Traitement, mesures, résiduel, suivi	70–82

Les exemples graphiques de ce dossier utilisent des noms fictifs et des valeurs de démonstration. Les règles et étapes supplémentaires de validation de l’application sont signalées comme propositions. Le texte intégral ISO/IEC 27005 n’a pas été consulté : aucune certification ou conformité normative n’est revendiquée. Les références Annex A visent bien ISO 27001:2022, selon la confirmation utilisateur.

Navigation simplifiée — ajout après analyse de la vidéo

Ce que montre la référence

Vidéo fournie le 14 octobre 2026, durée 2 min 02, résolution 1912×914, sans piste audio. Lecture visuelle par captures réparties sur toute la séquence, avec inspection en détail des menus. La vidéo montre une autre application GRC : elle constitue une référence d'organisation, pas une preuve des fonctions de legacy ni une demande de reprendre son identité graphique. Les images et données affichées dans la vidéo ne sont pas publiées dans ce dossier.

Repères approximatifs : début, tableau de bord et menu métier ; 7–15 s, indicateurs et actions ; 17–40 s, contexte, enjeux, parties intéressées et objectifs ; 42–49 s, organisation et risques ; 52–70 s, exigences, mappings et fournisseurs ; 72–80 s, constats et incidents ; 82–100 s, catégories et échelles ; 102–122 s, notifications, validations et paramètres.

À retenir : familles métier, sous-menus repliables, table de travail cohérente avec recherche/filtres/colonnes. La vidéo conserve elle-même de nombreuses entrées et sépare Configuration, Workflow et Paramétrage ; notre proposition regroupe ces administrations pour alléger davantage le menu. Le style 08 retenu reste la référence visuelle.

Doublons confirmés et faux doublons

Le code actuel modules/navigation-ui.js répartit 24 sections dans quatre groupes. L'inventaire documentaire antérieur décrit 100 destinations ; il est utilisé comme base de correspondance, pas comme décompte certifié de toutes les routes au prochain SHA.

Cas	Preuve / distinction	Décision proposée
Comptes et habilitations dans Périmètres et Administration	modules/admin-ui.js:111 appelle U.accounts() ; modules/integration-ui.js:405 fait de même	Une destination principale, anciens IDs en alias ; conserver l'accès annuaire déjà autorisé
Rôles et responsabilités dans Périmètres et Administration	admin-ui.js:112 appelle U.rolesView() ; registre partagé roles	Une destination principale Organisation → Rôles et responsabilités ; contexte admin sous forme de lien
Ancien Contexte → Rôles	navigation-ui.js filtre ctx-roles et redirige vers perimeters/roles	Doublon déjà traité : conserver la compatibilité, ne pas le recréer
Actions CaRE, HAS, PCRA, IA et plan global	Vues métier contextualisées ; même libellé ne prouve pas une duplication de stockage	Un accès transversal Actions, liens contextuels dans les modules ; adapter les filtres sans fusion aveugle des données
Preuves globales et preuves CaRE/HAS/PCRA	Versions et restrictions métier distinctes	Documents centralise l'accès ; les preuves contextualisées restent dans leurs parcours
Tableaux de bord par domaine	Synthèses différentes	Une synthèse principale ; synthèses locales à l'intérieur des modules
Matrice des risques et cartographie SMSI	Objets et interactions distincts	Matrice dans Risques ; cartes SMSI accessibles sans aucun changement du module
Politiques de risque et d'impact PCRA	Configurations distinctes, parfois compatibles	Administration GRC commune avec types/versions ; conserver les règles spécifiques et les lectures contextuelles

Cas	Preuve / distinction	Décision proposée
Référentiels de conformité et catégories administrables	Mesures/exigences versus paramètres de classement	Conformité pour le travail métier ; Administration pour gérer les définitions
Incidents, crise et PCRA	Signalement, gestion de crise, préparation/reprise	Même famille Résilience, modules et états conservés

Arborescence proposée : sept rubriques métier

Rubrique	Entrées secondaires
Pilotage	Vue d’ensemble ; Objectifs & indicateurs ; Rapports & comités ; Budgets & investissements
Organisation	Contexte & périmètres ; Processus & actifs ; Fournisseurs ; Rôles & responsabilités ; Cartographies du SMSI
Risques	Registre des risques ; Études & parcours ; Scénarios ; Traitements ; Gouvernance de l’IA
Conformité & audits	Conformité & applicabilité ; Audits ; CaRE ; HAS ; Écarts applicatifs
Actions	Plan d’action ; Tâches récurrentes ; Programmes & formation
Résilience	Incidents & crise ; PCRA · continuité ; CRRC · sauvegardes
Documents	Accès direct aux preuves et documents, avec vues internes

Administration, séparée en bas : Configuration GRC ; Comptes & habilitations ; Référentiels administrés ; Apparence ; Journal & données. Configuration GRC contient les échelles, critères, matrices, catégories, méthodes et validations de parcours en onglets internes. L’accès à chaque fonction conserve ses permissions serveur ; le regroupement ne donne aucun droit supplémentaire.

Mon compte, aide, parcours de démarrage et notifications réellement disponibles se placent dans les utilitaires. Ne pas créer un centre de notifications inexistant pour imiter la vidéo. Les fonctions CRRC, CaRE, HAS, budgets, IA et écarts applicatifs sont toutes conservées.

Règles d’épuration

- Un seul niveau de familles et un seul niveau de destinations dans la barre latérale. Les subdivisions plus fines sont des onglets de page, jamais une quatrième profondeur d’accordéon.

- Un groupe ouvert à la fois par défaut. Chevrons orientés, icônes colorées, libellés complets, focus visible et aria-expanded ; aucun signe +/−.

- Un objet possède une destination principale. Les accès depuis les autres modules sont des liens contextualisés conservant l’identifiant, les filtres et le bouton de retour.

- Liste, Kanban, calendrier, planning, Gantt et synthèse restent des vues d’un même registre. Ne pas créer six menus pour six présentations.

- Les tâches récurrentes restent une entrée visible sous Actions : leurs occurrences et leur historique ne sont pas fusionnés avec les actions ponctuelles.

- Dans Risques, « Matrice » est un onglet du registre ; « Études & parcours » expose les méthodes autorisées. Les cinq ateliers sont dans l’étude, pas cinq menus globaux.

- La cartographie dynamique garde exactement ses routes, composants et comportements. Seul son point d’accès est classé sous Organisation ; aucun habillage interne.

- Aucune rubrique « Divers », « Autres modules » ou « Outil de suivi ancien » fourre-tout. Un alias historique peut rester utilisable sans être une entrée principale permanente.

Contrat d’implémentation de la navigation

Créer une configuration de navigation **de présentation**, indépendante des registres métier. Chaque destination possède id, label, icon, groupId, route, requiredCapabilities, aliases, contextPolicy. Les routes restent celles de legacy ; une destination nouvelle est explicitement marquée proposée et ne devient visible qu’après implémentation. L’annexe JSON décrit les familles cibles ; le CSV contient les correspondances des destinations documentées et des alias historiques repérés.

Modifier l’assemblage navDef/LegacyNavigation.organize et le rendu de la barre après tests, sans dupliquer les définitions dans plusieurs composants. Transformer navOrder, navGroups, navLast et l’historique local en conservant les préférences compatibles ; ignorer proprement les IDs retirés de l’affichage. Un ancien favori doit ouvrir sa destination canonique autorisée. Les aliases n’accordent aucune capacité et ne contournent pas la projection serveur.

Conserver les variantes lecteur/éditeur/administrateur. « Administration » n’implique pas que ses sous-écrans soient tous réservés au rôle admin si un annuaire était auparavant consultable : dissocier lecture d’annuaire et modification des habilitations, sans réduire silencieusement un accès autorisé. Le serveur demeure l’autorité.

Validation de la proposition et recette dédiée

Les dix vues du dossier utilisent désormais cette barre simplifiée. Deux captures supplémentaires montrent le menu replié et le groupe Risques ouvert. Ce sont des propositions à valider, pas un changement du runtime.

Tests à écrire pour l’intégration : toutes les destinations du registre effectif ont une correspondance ; chaque destination principale apparaît une seule fois ; les anciens IDs fonctionnent ; recherche/favoris/retour conservent leur état ; accès lecteur/éditeur/admin identiques ; aucun panneau de cartographie changé ; accès direct aux tâches récurrentes, actions, preuves et cinq ateliers maintenu ; navigation clavier et affichage étroit ; pas de libellé tronqué sans alternative lisible.

Faire un essai utilisateur de cinq tâches : retrouver une preuve, planifier une tâche récurrente, ouvrir une étude EBIOS, retrouver un fournisseur, gérer une habilitation. Mesurer les erreurs de chemin et les retours en arrière avant/après ; ne pas inventer un gain chiffré sans mesure.

Prompt à donner à l’IA qui code

Tu dois faire évoluer l’application existante yousername-ha/suivi-audits vers le socle GRC transversal décrit dans implementation/grc-transversal/v001-dossier-arm/. Commence par lire son README.md, puis tous les documents 01 à 12, les contrats, les annexes et les vues graphiques. Si tu reçois le ZIP, utilise son contenu et rapproche-le du dépôt ; le ZIP est un dossier de spécification, pas le code complet de l’application.

Branche : tu es autorisé à travailler, committer et publier exclusivement sur TA PROPRE branche dédiée, créée depuis la référence de lecture origin/legacy, par exemple implementation/grc-transversal-arm. Ne commets et ne pousse jamais sur legacy, main ou une branche d’un autre intervenant. Ne fusionne pas, ne déploie pas, ne déclenche pas de CI/release. Cette consigne explicite prévaut sur une consigne historique d’AGENTS.md imposant legacy à l’agent qui préparait les maquettes. Respecte les autres invariants applicables. Si tu ne peux pas créer ta branche sans toucher à du travail étranger, utilise un worktree isolé.

La référence auditée dans le dossier est le SHA 472a81fe315ac323d75a59db74e16b8d39a5b0e8. Relève ton SHA de départ et les changements intervenus depuis ; ne remplace pas aveuglément le code récent par les propositions du dossier. Les répertoires non suivis ou travaux d’autres intervenants ne sont pas à supprimer, déplacer ou publier.

Objectif : un socle partagé de registres et de configurations versionnées, plusieurs méthodes d’analyse, des études qui épinglent leurs versions et des évaluations propres au contexte. Réutilise les registres existants de fournisseurs, périmètres, rôles, processus, risques, actions, preuves, mesures et décisions. N’ajoute un registre que si aucun équivalent canonique n’existe après audit. Conserve SQLite, le serveur, ses sessions/CSRF et ses contrôles ; aucune application parallèle.

Ordre : exécute les lots 0 à 8 de 09-PLAN-IMPLEMENTATION.md, avec les portes de sortie définies. Valide côté serveur toute nouvelle collection, référence, portée, publication et transition ; ne te limite pas à l’interface. Ne publie pas une méthode ou une configuration avec des dépendances ambiguës. Préserve les historiques immuables, les identifiants, les anciennes évaluations et les exports. Prévois migration sur copie, idempotence, contrôle de concurrence et restauration testée.

L’export ARM décrit les ateliers 1–2 seulement : 21 classeurs, 8 échelles, 3 images, 9 missions sur 89 lignes physiques. Les fichiers réels ne sont pas dans le dossier public. Ne fabrique aucune VM, association manquante, évaluation de couple ou donnée des ateliers 3–5. Utilise les annexes structurelles et des fixtures fictives ; si un import réel est nécessaire, demande l’archive à l’utilisateur au moment opportun et garde-la hors Git. Ne traite pas les images comme un schéma de base de données. Conserve les cas accidentels mais demande leur classement avant validation dans un parcours d’attaque intentionnelle.

EBIOS RM conserve ses cinq ateliers et ses livrables reliés. Les configurations de pertinence, gravité, vraisemblance et impact sont distinctes. Les échelles qualitatives n’imposent aucune valeur numérique. La matrice ARM de pertinence est un mapping explicite 3×3, pas une multiplication. Les autres méthodes n’héritent pas automatiquement des ateliers ou des SR/OV EBIOS. Préserve MÉHARI historique ; n’annonce pas un moteur complet sans source ni recette.

UI : conserve le style 08, les icônes colorées et les chevrons de dépliage. Le tableau de suivi pilote les vues associées ; distingue cercle/matrice de pertinence et matrice des risques. Les chemins sélectionnés ont un flux animé dans le sens des flèches et des contours renforcés ; respecte le mouvement réduit. Les thèmes clair/sauge sont un choix global administré. Les captures sont des maquettes à valider, pas des composants déjà intégrés.

Ne modifie ni le fonctionnement ni l’interface de la cartographie dynamique : protège modules/carto-core.js, modules/carto-ui.js, modules/carto.css, legacy_cartography.py et les routes/éléments identifiés dans le diagnostic. Les graphes EBIOS et matrices de risques vivent dans leur module. Garde les liens bidirectionnels risques–Annexe A ISO 27001:2022 ; un rattachement ou une action clôturée ne valide pas la conformité ou le résiduel.

Pose une question courte seulement lorsqu’une décision métier bloque réellement le lot : limites de disponibilité, agrégation des impacts, organisation propriétaire, édition ISO, rapprochements réels. N’invente pas la réponse. Continue le travail indépendant. Les détails techniques réversibles peuvent être résolus avec jugement dans le cadre autorisé.

Pour chaque lot : code et tests adaptés, résultat réel des commandes, captures synthétiques, changements de schéma, risques résiduels et SHA. Applique 10-RECETTE.md, notamment isolation, immutabilité, concurrence, parcours complet, non-régression et export. Ne marque pas un test passé sans exécution. À la fin, fournis le lien de TA branche, le dossier actualisé, un bilan de recette et les instructions de lancement. Aucune fusion ou mise en production automatique.

Navigation : applique le chapitre 12 et ses annexes après revue de la proposition. Sept rubriques métier, Administration séparée, une destination principale par fonction, chevrons et icônes colorées. Conserve les anciens IDs en alias, les liens contextuels, les préférences compatibles et les permissions. Ne confonds pas un doublon de menu avec un doublon de données ; ne supprime aucune fonction pour alléger la barre. Les tâches récurrentes restent visibles sous Actions. Ne touche pas au module de cartographie dynamique.